AKTE W5·3

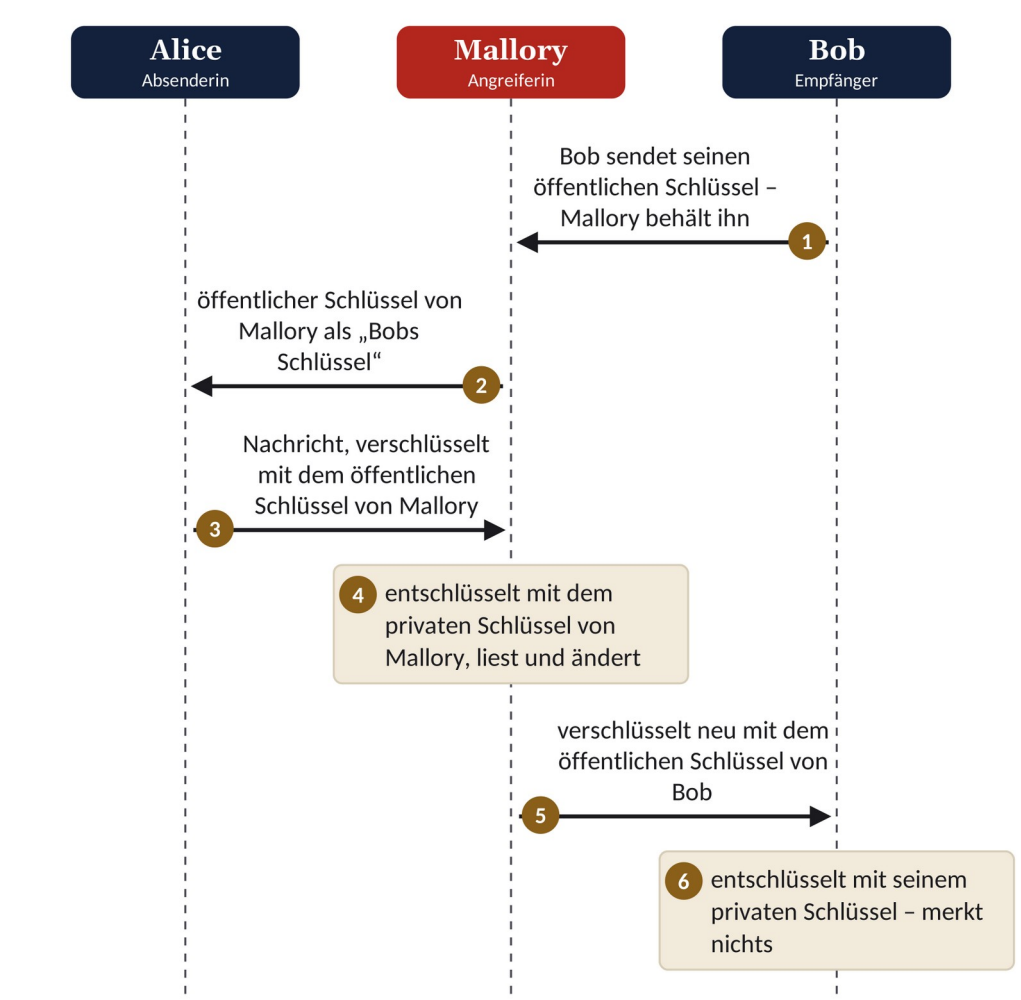
Mallory im Netz

KERN LÖSUNG

ARCHIVFUND

Im Funkraum hat Mallory gezeigt, was passiert, wenn niemand prüft, wem ein öffentlicher Schlüssel gehört. Erst als Trent die Schlüssel mit seinem Siegel bestätigte, flog sie auf. Heute erledigt das jeder Browser tausendfach am Tag – fast unsichtbar. Und weil im Netz so viele Daten über uns fließen, hat Europa Regeln dafür geschaffen, wer was speichern darf.

ARCHIVWISSEN 1 · DER MAN-IN-THE-MIDDLE-ANGRIFF



Mallory bricht **kein** Verfahren – sie nutzt aus, dass Alice nicht prüft, wem der Schlüssel gehört. Gebrochen sind Vertraulichkeit (Mallory liest) und Integrität/Authentizität (Mallory ändert und gibt sich als Bob bzw. Alice aus). Auch **Diffie-Hellman** (W4) ist ohne Prüfung anfällig: Mallory vereinbart je einen Schlüssel mit Alice und mit Bob.

© Frank Juchim · Kryptos · für den Unterricht

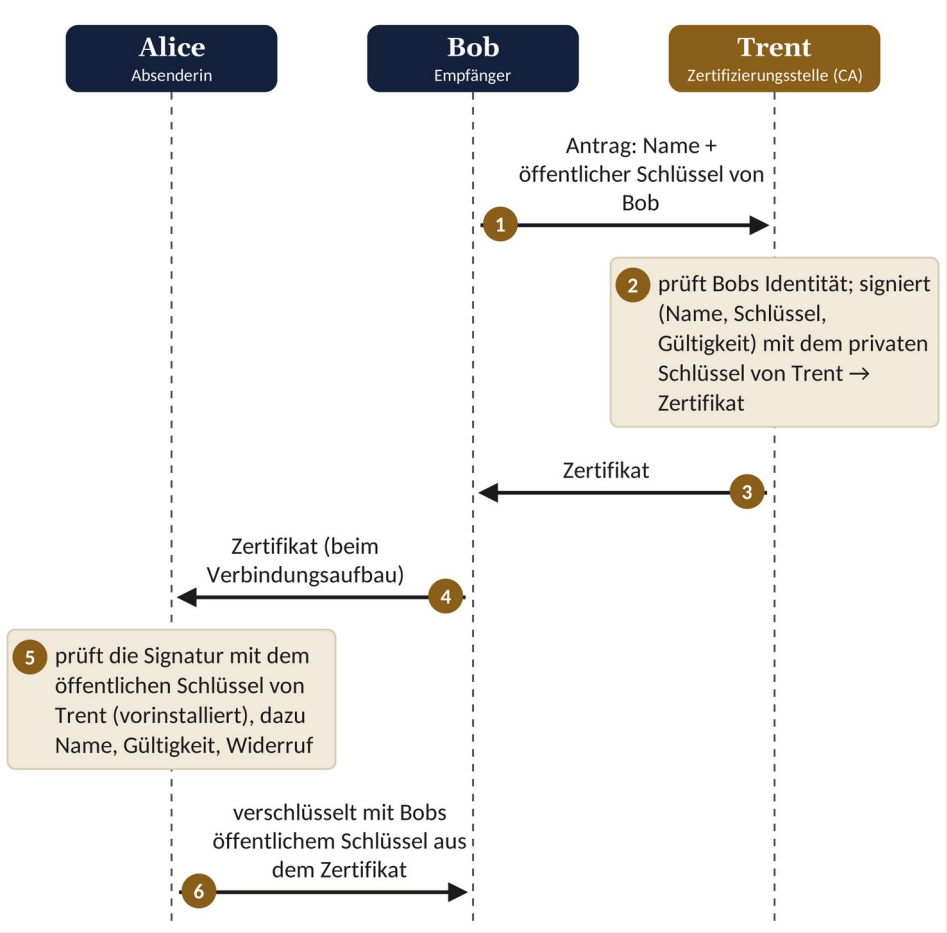
ARCHIVWISSEN 2 · ZERTIFIKATE

Ein **Zertifikat** ist ein von einer **Zertifizierungsstelle (CA)** signiertes Dokument (Beispiel, erfunden):

Inhaber	`bank-chronopolis.example`
Öffentlicher Schlüssel	RSA 2048 Bit, `30 82 01 0A 02 82 01 01` … (gekürzt)
Aussteller	Chronopolis CA
Gültig	01.09.2026 bis 15.03.2027
Seriennummer	`4F 2A 91 C3`
Signatur der CA	(Hashwert aller Angaben oben, verschlüsselt mit dem privaten Schlüssel der Chronopolis CA)

- **Ausstellung:** Die CA prüft, dass der Antragsteller die Domain bzw. Identität wirklich kontrolliert, und signiert die Zuordnung „öffentlicher Schlüssel ↔ Inhaber“.
- **Prüfung im Browser:** (1) Signatur mit dem **öffentlichen Schlüssel der CA** prüfen, (2) Name = aufgerufene Domain?, (3) gültig am heutigen Tag?, (4) nicht widerrufen (gesperrt)?
- **Zertifikatskette:** Serverzertifikat (signiert von Zwischen-CA) → Zwischenzertifikat (signiert von Wurzel-CA) → **Wurzelzertifikat** (selbst signiert, im Browser/Betriebssystem als **Vertrauensanker** vorinstalliert).
- **Web of Trust** (z. B. OpenPGP): Ohne zentrale CA bestätigen sich Nutzerinnen und Nutzer gegenseitig ihre Schlüssel durch Signaturen; man vertraut einem Schlüssel, wenn Personen, denen man vertraut, ihn bestätigt haben.

So bestätigt Trent (CA) Bobs Schlüssel:



 © Frank Juchim · Kryptos · für den Unterricht

ACHTUNG FALLE P9 · Was ein Zertifikat bestätigt

Ein Zertifikat bestätigt **die Zuordnung Schlüssel ↔ Identität**, nicht die Ehrlichkeit des Inhabers. Auch Betrugsseiten haben gültige Zertifikate – für **ihren eigenen** Namen (vgl. `chronoskop-archiv.example` im Archivfund).

ARCHIVWISSEN 3 · TLS (HTTPS) IM ÜBERBLICK

1. Der Browser baut die Verbindung auf und nennt die Verfahren, die er beherrscht.
2. Der Server schickt sein Zertifikat (mit Kette).
3. Der Browser prüft Zertifikat und Kette bis zu einem Vertrauensanker sowie Name und Gültigkeit.
4. Browser und Server vereinbaren **asymmetrisch** einen gemeinsamen Sitzungsschlüssel (heute mit Diffie-Hellman, wobei der Server seinen Teil mit dem Schlüssel aus dem Zertifikat signiert; ältere Versionen übertrugen einen Schlüssel RSA-verschlüsselt).
5. Alle Daten werden **symmetrisch** (z. B. AES) mit dem Sitzungsschlüssel verschlüsselt und gegen Veränderung gesichert.

→ TLS = **Zertifikatsprüfung + Hybridverfahren**. Das Schloss-Symbol bedeutet: verschlüsselt mit dem Inhaber des Zertifikats – nicht „diese Seite ist harmlos“.

ARCHIVWISSEN 4 · DATENSCHUTZ: DSGVO UND INFORMATIONELLE SELBSTBESTIMMUNG

Personenbezogene Daten sind alle Informationen, die sich auf eine identifizierte oder identifizierbare Person beziehen (Name, Adresse, Standort, Fotos, Kennnummern …). Das **Recht auf informationelle Selbstbestimmung** (Bundesverfassungsgericht 1983, „Volkszählungsurteil“) besagt, dass jede und jeder grundsätzlich selbst über Preisgabe und Verwendung der eigenen Daten bestimmt. Die **Datenschutz-Grundverordnung (DSGVO)** gilt seit dem 25. Mai 2018 und legt in Art. 5 **Grundsätze** fest:

Grundsatz	Kurzform
Rechtmäßigkeit, Verarbeitung nach Treu und Glauben, Transparenz	nur mit Rechtsgrundlage (z. B. Einwilligung, Vertrag, Gesetz), nachvollziehbar für Betroffene
Zweckbindung	nur für festgelegte, eindeutige Zwecke
Datenminimierung	nur so viele Daten wie für den Zweck nötig
Richtigkeit	Daten müssen sachlich richtig sein, falsche werden berichtigt oder gelöscht
Speicherbegrenzung	nur so lange speichern wie nötig
Integrität und Vertraulichkeit	angemessene Sicherheit, z. B. Verschlüsselung, Zugriffsschutz, Passwort-Hashing
Rechenschaftspflicht	der Verantwortliche muss die Einhaltung nachweisen können

Betroffene haben u. a. Rechte auf **Auskunft, Berichtigung, Löschung** und **Widerspruch**.

© Frank Juchim · Kryptos · für den Unterricht

ARCHIVWISSEN 5 · VERSCHLÜSSELUNG UND GESELLSCHAFT: EINE DEBATTE

Starke Ende-zu-Ende-Verschlüsselung schützt Privatsphäre, Geschäftsgeheimnisse, Journalistinnen und Journalisten – erschwert aber auch Ermittlungen. Seit Jahrzehnten wird deshalb über staatlichen Zugriff gestritten (in den 1990er-Jahren „Crypto Wars“ um Hintertüren und Schlüsselhinterlegung). Aktuell diskutiert die EU seit 2022 eine Verordnung zur Bekämpfung von Darstellungen sexuellen Kindesmissbrauchs im Netz, die Anbieter zum automatischen Durchsuchen von Nachrichten verpflichten könnte – auch **vor** der Verschlüsselung auf dem Gerät („Client-Side-Scanning“, umgangssprachlich „Chatkontrolle“).

Argumente dafür (Auswahl)

- Schutz von Opfern schwerer Straftaten
- Ermittlungsmöglichkeiten dürfen nicht durch Technik verschwinden
- Anbieter tragen Verantwortung für ihre Dienste

Argumente dagegen (Auswahl)

- anlassloses Durchsuchen aller Kommunikation (Verhältnismäßigkeit, informationelle Selbstbestimmung)
- Fehlalarme treffen Unschuldige
- eine eingebaute Prüffunktion ist eine Schwachstelle, die missbraucht oder erweitert werden kann
- Vertraulichkeit der Ende-zu-Ende-Verschlüsselung wird untergraben

Es gibt hier keine „richtige“ Meinung: Bewertet wird, wie sachlich und begründet du abwägst. Stand der Gesetzgebung: siehe aktuelle Nachrichtenlage.

1 AUFTRAG ★ Mallorys Schlüsseltausch EINZELARBEIT · 6 MIN

Beschrifte im Schaubild (Archivwissen 1) an den Stellen (1) bis (4) – Pfeile 2 bis 5 – den verwendeten Schlüssel (**Art + Inhaber**). **Nenne** die Schutzziele, die Mallory bricht.

LÖSUNG P9

(1) Pfeil 2: **öffentlicher Schlüssel von Mallory** (ausgegeben als Bobs), (2) Pfeil 3: **öffentlicher Schlüssel von Mallory**, (3) Pfeil 4: **privater Schlüssel von Mallory**, (4) Pfeil 5: **öffentlicher Schlüssel von Bob**.

Gebrochen: **Vertraulichkeit, Integrität, Authentizität**.

2 AUFTRAG ★★ Drei Zertifikate PARTNERARBEIT · 10 MIN

Alice ruft am 12.10.2026 `bank-chronopolis.example` auf. Mallory kann ihr eines von drei Zertifikaten unterschieben:

	Inhaber	Aussteller	gültig	Signatur
Z1	`bank-chronopolis.example`	Chronopolis CA	01.09.2026–15.03.2027	korrekt
Z2	`chronopolis-bank.example`	Chronopolis CA	01.10.2026–31.03.2027	korrekt
Z3	`bank-chronopolis.example`	Mallory Root	01.10.2026–31.03.2027	korrekt mit Mallorys Schlüssel

Mallorys Wurzelzertifikat ist nicht im Browser installiert. **Entscheide** für jedes Zertifikat begründet, ob der Browser es akzeptiert. Welches der drei Zertifikate kann Mallory nur benutzen, wenn Alice sich auf die falsche Adresse locken lässt?

© Frank Juchim · Kryptos · für den Unterricht

LÖSUNG P9

Z1: akzeptiert (Name passt, gültig, Kette zur vorinstallierten Wurzel) – aber Mallory hat den passenden privaten Schlüssel der Bank nicht, kann also mit Z1 nicht als Bank auftreten.

Z2: Name passt nicht zu `bank-chronopolis.example` → Warnung; **nur nutzbar, wenn Alice auf `chronopolis-bank.example` gelockt wird** (Phishing, vgl. Archivfund) – dann zeigt der Browser sogar ein Schloss.

Z3: Kette endet bei „Mallory Root“, das nicht vorinstalliert ist → Warnung (nicht vertrauenswürdige Zertifizierungsstelle).

3 AUFTRAG ★★ Bis zur Wurzel EINZELARBEIT · 8 MIN

a) Ergänze im Schaubild in Archivwissen 2 an den Stellen (1) und (2) **Schlüsselart und Inhaber**.

b) **Beschreibe** die Prüfung der Kette „Trent Root CA → Chronopolis CA → `bank-chronopolis.example`“ Schritt für Schritt (welche Signatur wird mit welchem öffentlichen Schlüssel geprüft?).

c) **Begründe**, warum die Kette mit einem vorinstallierten Zertifikat enden muss.

LÖSUNG P9

a) (1) **privater Schlüssel von Trent**, (2) **öffentlicher Schlüssel von Trent** (im Browser vorinstalliert).

b) Signatur im Serverzertifikat mit dem öffentlichen Schlüssel der **Chronopolis CA** (steht im Zwischenzertifikat) prüfen; Signatur im Zwischenzertifikat mit dem öffentlichen Schlüssel der **Trent Root CA** prüfen; Trent Root CA ist im Browser vorinstalliert → das Vertrauen endet hier.

c) Irgendeinem Schlüssel muss man ohne weitere Prüfung vertrauen; würde der Server auch die Wurzel liefern, könnte Mallory eine eigene Wurzel mitschicken.

4 AUFTRAG ★★ TLS-Kärtchen PARTNERARBEIT · 8 MIN

Bringe die gemischten TLS-Schritte in die richtige Reihenfolge und **begründe**, warum TLS ein Hybridverfahren ist und warum die Zertifikatsprüfung **vor** der Schlüsselvereinbarung stehen muss.

	Kärtchen	Platz
A	Browser und Server vereinbaren asymmetrisch einen gemeinsamen Sitzungsschlüssel.	
B	Der Server schickt sein Zertifikat (mit Kette).	
C	Alle Daten werden symmetrisch mit dem Sitzungsschlüssel verschlüsselt.	
D	Der Browser baut die Verbindung auf und nennt die Verfahren, die er beherrscht.	
E	Der Browser prüft Zertifikat und Kette bis zu einem Vertrauensanker sowie Name und Gültigkeit.	

LÖSUNG P5

Reihenfolge **D – B – E – A – C** (wie Archivwissen 3).

Hybrid: asymmetrisch nur für die Vereinbarung des Sitzungsschlüssels (keine geheime Vorabsprache mit dem Server möglich), symmetrisch für die Daten (Geschwindigkeit). Zertifikat zuerst: sonst vereinbart der Browser womöglich einen Schlüssel mit Mallory (Man-in-the-Middle).

5 AUFTRAG ★★ Der Messenger „Funkspruch“ GRUPPENARBEIT · 10 MIN

Der (erfundene) Messenger „Funkspruch“ wirbt mit Ende-zu-Ende-Verschlüsselung. In seinen Bedingungen steht:

1. Beim Start wird das gesamte Adressbuch hochgeladen.

 © Frank Juchim · Kryptos · für den Unterricht

2. Chats werden unbegrenzt auf dem Server gesichert.
3. Der Standort wird für personalisierte Werbung genutzt, obwohl er für die Funktion nicht nötig ist.
4. Auskunftsanfragen beantwortet der Anbieter nicht.
5. Passwörter werden im Klartext gespeichert.

Ordne jedem Punkt einen verletzten DSGVO-Grundsatz bzw. ein Betroffenenrecht zu und **schlage** je eine Verbesserung vor.

LÖSUNG P10

Nr.	verletzter Grundsatz / Recht	Verbesserungsvorschlag
1	Datenminimierung, Rechtmäßigkeit (Kontakte Dritter ohne deren Einwilligung)	nur gehashte bzw. freiwillig ausgewählte Kontakte abgleichen
2	Speicherbegrenzung	Löschfristen, Speicherung nur auf Wunsch
3	Zweckbindung, Datenminimierung	Standort nur mit ausdrücklicher Einwilligung und nur für die Funktion
4	Auskunftsrecht, Transparenz, Rechenschaftspflicht	Auskunft binnen eines Monats
5	Integrität und Vertraulichkeit	gesalzene, langsame Passwort-Hashes

6 AUFTRAG ★★★ Scannen vor dem Verschlüsseln? EINZELARBEIT · HAUSAUFGABE

Erörtere auf einem eigenen Blatt (ca. 250 Wörter) die Frage: „Sollen Messenger-Anbieter verpflichtet werden, Nachrichten vor der Verschlüsselung automatisch auf verbotene Inhalte zu prüfen?“

- ☐ **Einleitung:** Sachverhalt und Fachbegriffe (Ende-zu-Ende-Verschlüsselung, Client-Side-Scanning)
- ☐ mindestens **zwei Argumente je Seite**, jeweils mit Beispiel
- ☐ **Abwägung** der Argumente
- ☐ **eigenes, begründetes Urteil**
- ☐ Bezug zu mindestens einem **Schutzziel** und einem **DSGVO-Grundsatz** bzw. der **informationellen Selbstbestimmung**

LÖSUNG P10

Bewertungskriterien: Sachverhalt korrekt (Prüfung **vor** der Verschlüsselung, das Verfahren selbst bleibt ungebrochen); je Seite ≥ 2 Argumente mit Beispiel; Bezug zu Vertraulichkeit und informationeller Selbstbestimmung/DSGVO; Abwägung (z. B. Verhältnismäßigkeit, Missbrauchsrisiko vs. Opferschutz, Alternativen wie gezielte Ermittlungen); begründetes eigenes Urteil.

Jede Position ist zulässig – bewertet wird die Qualität der Argumentation (P10).

7 AUFTRAG ★★★ Mallory gegen Diffie-Hellman PARTNERARBEIT · 10 MIN eA

(Rechnung: Ergänzung, DH aus W4) p = 23, g = 5. Alice wählt a = 6, Bob b = 9. Mallory fängt beide öffentlichen Werte ab und schickt beiden ihren Wert $M = 5^m \bmod 23$ mit m = 4.

a) Berechne A, B und M.

b) Berechne den Schlüssel, den Alice berechnet ($M^a \bmod 23$), und den, den Bob berechnet ($M^b \bmod 23$).

c) Welche Schlüssel kennt Mallory? Welchen Schlüssel hätten Alice und Bob ohne Mallory?

d) **Erläutere**, wie signierte DH-Werte (Server-Zertifikat in TLS) den Angriff verhindern.

© Frank Juchim · Kryptos · für den Unterricht

LÖSUNG P9

Größe	Rechnung	Wert
A	$5^6 \bmod 23$	**8**
B	$5^9 \bmod 23$	**11**
M	$5^4 \bmod 23 = 625 \bmod 23$	**4**
K_{Alice}	$M^a = 4^6 \bmod 23 = 4096 \bmod 23$	**2**
K_{Bob}	$M^b = 4^9 \bmod 23$	**13**

c) Mallory berechnet $A^m = 8^4 \bmod 23 = 2$ und $B^m = 11^4 \bmod 23 = 13$ – sie kennt **beide** Schlüssel. Ohne Mallory: $K = 5^{54} \bmod 23 =$ **9**.

d) Signiert der Server seinen DH-Wert mit dem privaten Schlüssel aus seinem Zertifikat, prüft der Browser die Signatur mit dem öffentlichen Schlüssel aus dem (CA-geprüften) Zertifikat; Mallorys Ersatzwert hätte keine gültige Signatur.

© Frank Juchim · Kryptos · für den Unterricht

ABI-CHECK · ca. 20 min 12 BE

a) **Erläutern Sie**, wie ein Angreifer mithilfe eines gefälschten öffentlichen Schlüssels die Vertraulichkeit und die Integrität der Kommunikation zwischen zwei Personen aushebeln kann. **[4 BE]**

ERWARTUNG a)

Der Angreifer fängt den öffentlichen Schlüssel des Empfängers ab und gibt seinen eigenen als dessen aus (1); der Absender verschlüsselt mit dem Angreiferschlüssel, der Angreifer entschlüsselt und liest (Vertraulichkeit) (1); er kann die Nachricht verändern (1) und mit dem echten öffentlichen Schlüssel des Empfängers neu verschlüsseln, sodass niemand etwas bemerkt (Integrität) (1).

b) **Beschreiben Sie**, wie ein Zertifikat einer Zertifizierungsstelle diesen Angriff verhindert. **[3 BE]**

ERWARTUNG b) P9

Eine CA bestätigt mit ihrer digitalen Signatur, dass ein öffentlicher Schlüssel zu einer bestimmten Person/Domain gehört (1); der Absender prüft die Signatur mit dem öffentlichen Schlüssel der CA, der z. B. im Browser vorinstalliert ist (1); ein untergeschobener Schlüssel hat kein gültiges Zertifikat auf den Namen des Empfängers, der Angriff fällt auf (1).

c) **Entscheiden Sie** begründet, ob die folgende Aussage korrekt ist: „Eine Website mit gültigem Zertifikat ist vertrauenswürdig.“ **[2 BE]**

ERWARTUNG c) P9

Falsch (1): Das Zertifikat bestätigt nur die Zuordnung des öffentlichen Schlüssels zur Domain bzw. zum Inhaber; auch Betrüger erhalten Zertifikate für eigene Domains (1).

d) **Nennen Sie** drei Grundsätze der DSGVO für die Verarbeitung personenbezogener Daten. **[3 BE]**

ERWARTUNG d)

Drei aus: Rechtmäßigkeit/Treu und Glauben/Transparenz, Zweckbindung, Datenminimierung, Richtigkeit, Speicherbegrenzung, Integrität und Vertraulichkeit, Rechenschaftspflicht (je 1).

IM LAB ÜBEN Level 5.3

Level 5.3 „Mallory im Netz“ im Kryptolabor mit dem **Zertifikats-Simulator** (Modi „Zertifikat“ und „MitM“). Danach: **Boss W5 „Das Siegel der Stadt“** – ab 50 % gehört das Artefakt „Siegel“ dir. Trainingsplatz: „Schutzziele“.

© Frank Juchim · Kryptos · für den Unterricht